

# INFORME FINAL DE AUDITORÍA DE SEGURIDAD IoT

## EVALUACIÓN DE VECTORES DE ATAQUE INALÁMBRICOS CONTRA DISPOSITIVO ESP32-C6



SEGURIDAD Y LEGALIDAD (SyL)  
CURSO 2025-2026

AUTOR  
GISSELA PATRICIA TASIGUANO SIMBAÑA  
ARIEL GÁMEZ DÍAZ

PROFESORA  
SARA ROMÁN NAVARRO

MÁSTER EN INGENIERÍA INFORMÁTICA  
FACULTAD DE INFORMÁTICA  
UNIVERSIDAD COMPLUTENSE DE MADRID

# Título

Evaluación Experimental de la Postura de Seguridad de un Dispositivo IoT (ESP32-C6) frente a Ataques de Reconocimiento, Interrupción de Servicio e Interceptación Man-in-the-Middle.

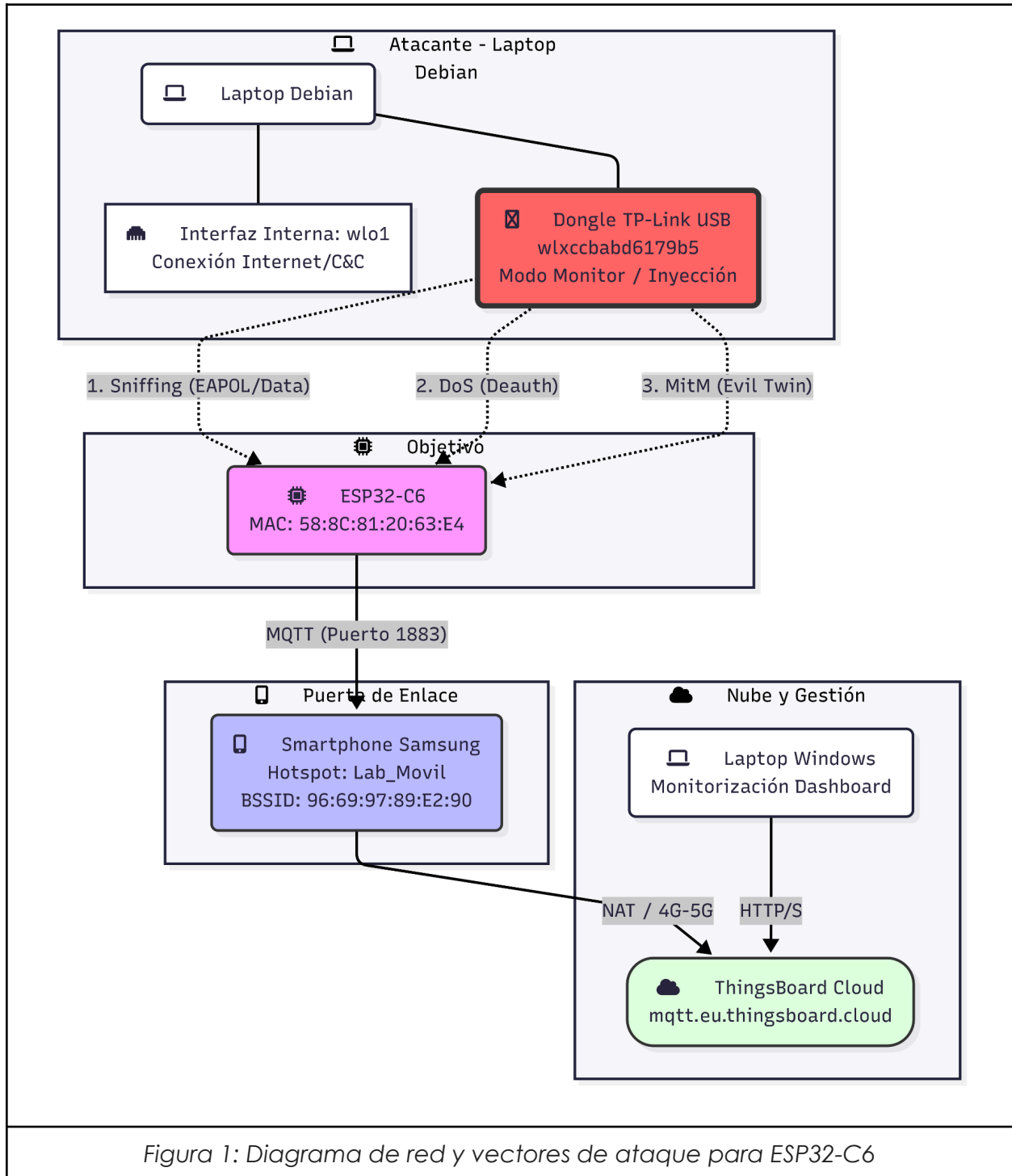
## Breve Descripción

Este informe detalla una auditoría de seguridad real (no simulada) realizada sobre un ecosistema IoT controlado en un entorno académico. El objetivo principal fue evaluar la vulnerabilidad de un dispositivo ESP32-C6, configurado para enviar telemetría a la nube ThingsBoard Cloud, frente a vectores de ataque inalámbricos comunes (IEEE 802.11).

La auditoría se ejecutó en cuatro fases secuenciales: 1) Reconocimiento pasivo fuera de la red (Sniffing Capa 2); 2) Reconocimiento activo mediante interceptación con descifrado (Sniffing Capa 4/Payload); 3) Denegación de Servicio (DoS) por desautenticación; y 4) Interceptación Man-in-the-Middle (MitM) mediante la técnica de "Twin Evil" (Gemelo Malvado). Los resultados demuestran que la falta de cifrado a nivel de aplicación (MQTT sin TLS) y debilidades inherentes en los protocolos de gestión Wi-Fi permiten comprometer totalmente la confidencialidad, integridad y disponibilidad del sistema IoT.

# Capítulo 1 - Entorno de Auditoría

El entorno de prueba se diseñó para replicar fielmente un escenario de IoT doméstico o industrial, donde un dispositivo IoT depende de una pasarela móvil (Hotspot) para acceder a Internet.



## 1.1. Hardware Utilizado

1. **Auditor/Atacante (LAPTOP\_DEBIAN):** Estación de trabajo Linux Debian Pro, equipada con una tarjeta de red interna (WLO1) para internet/C&C y un Dongle USB TP-Link (WLXCCBABD6179B5) con chipset Atheros, esencial por su soporte nativo para Modo Monitor e Inyección de Paquetes.
2. **Observador (LAPTOP\_WINDOWS):** Equipo auxiliar utilizado exclusivamente para monitorizar el Dashboard de ThingsBoard Cloud y confirmar el estado de la conexión legítima del ESP32.
3. **Gateway IoT (SAMSUNG\_HOTSPOT):** Teléfono móvil Samsung actuando como Punto de Acceso Wi-Fi (AP) con el SSID: "Lab\_Movil" (BSSID: 96:69:97:89:E2:90).
4. **Objetivo IoT (ESP32\_C6):** Microcontrolador ESP32-C6 (MAC legítima: 58:8C:81:20:63:E4) ejecutando firmware personalizado para enviar telemetría (RSSI y estado del intervalo) cada 5 segundos al servidor mqtt.eu.thingsboard.cloud mediante el protocolo MQTT (texto plano, puerto 1883).

## 1.2. Software y Herramientas

Se utilizó la suite de auditoría inalámbrica Aircrack-ng (aireplay-ng, hostapd-wpe), el analizador de protocolos Wireshark/Tshark, NetworkManager (nmcli), y herramientas de red estándar (iptables, dnsmasq).

## 1.3. Descripción del Flujo del Sistema

El ESP32-C6 se conecta al Hotspot "Lab\_Movil". Una vez obtiene IP (10.154.204.x), inicia la sincronización horaria vía NTP y conecta al Broker de ThingsBoard. El tráfico Wi-Fi legítimo viaja cifrado bajo el protocolo WPA2-Personal hacia el móvil, que actúa como NAT hacia el servidor en la nube de AWS donde se aloja ThingsBoard.

## Capítulo 2 - Explicación de los Ataques Realizados

La auditoría progresó desde la visualización externa del tráfico hasta la interceptación total y control de la conectividad.

### Ataque 1: Sniffing Inalámbrico y Análisis de Tráfico

Este vector de ataque se dividió en dos escenarios para demostrar la diferencia entre identificar el dispositivo y visualizar sus datos.

- **Escenario A: Sniffing Capa 2 (Fuera de la Red 'Lab\_Movil')**
  - **Metodología (*identificar\_esp32.sh*):** El Dongle TP-Link se aisló de NetworkManager, se configuró en Modo Monitor y se sintonizó en el Canal 11 (detectado mediante escaneo previo del SSID "Lab\_Movil"). Se utilizó tshark con el filtro de visualización wlan.fc.type == 2 para capturar exclusivamente tramas de datos inalámbricas en crudo.
  - **Resultados:** No se pudo visualizar el contenido de los paquetes (IP o puertos TCP) debido al cifrado WPA2. Sin embargo, el análisis de patrones de tráfico de Capa 2 reveló ráfagas constantes de datos (4 tramas EAPOL seguidas de tráfico de datos TCP regular) emitidas por la MAC desconocida (C6:DF:54... o la real 58:8C:81...) hacia el Gateway Samsung cada 5 segundos. Esta huella de tráfico coincidió perfectamente con la actualización del Dashboard de ThingsBoard, permitiendo la **identificación positiva** del ESP32 como el dispositivo IoT activo.
- **Escenario B: Sniffing Capa 4 e Interceptación de Payload (Descifrado WPA2)**
  - **Metodología (*descifrar\_mqtt.sh*):** Este ataque requirió el conocimiento previo de la credencial Wi-Fi de "Lab\_Movil" (hogz7998). Se configuró tshark para realizar un descifrado al vuelo (On-the-fly Decryption) cargando las claves de sesión WPA-PWD (uat:80211\_keys). Para que el descifrado fuera efectivo, el auditor tuvo que forzar un reinicio del ESP32 (quitar/poner corriente), permitiendo que el adaptador USB capturara el momento crítico de la conexión Wi-Fi (el 4-Way Handshake o EAPOL type 3).
  - **Resultados:** La captura exitosa del Handshake permitió derribar el muro del cifrado Wi-Fi. tshark reveló que el tráfico IoT viajaba por el **puerto 1883** (MQTT en texto plano). El auditor pudo visualizar la telemetría en tiempo real:
    - Hexadecimal: 7b2272737369...353030307d
    - ASCII Traducido: {"rssi":-26,"intervalo\_actual":5000}
  - **Conclusión Syl:** Se confirma un compromiso total de la confidencialidad. Los datos IoT, que podrían contener información sensible, son legibles por cualquier atacante que intercepte la conexión Wi-Fi.

### Ataque 2: Denegación de Servicio (DoS) por Desautenticación

- **Metodología (*ataque\_iot.sh*):** Este ataque explota una vulnerabilidad inherente al

protocolo IEEE 802.11 (Wi-Fi 5 o anteriores), donde las tramas de desautenticación (Management Frames) no están cifradas. Usando el Dongle TP-Link en modo monitor en el Canal 11, se lanzó aireplay-ng con el flag -0 0, enviando ráfagas continuas de tramas de desautenticación forjadas. La herramienta suplantó la dirección MAC del Gateway Samsung (BSSID\_MOVIL) y dirigió las tramas directamente a la MAC real del ESP32 (MAC\_ESP32).

- **Resultados:** El ESP32 perdió la conectividad inmediatamente. Los logs seriales confirmaron: W (7122) wifi station: disconnected, reason: 6 (AUTH\_EXPIRED/ASSOC\_LEAVING). El envío de telemetría a ThingsBoard se detuvo instantáneamente, confirmando la interrupción del servicio y comprometiendo gravemente la disponibilidad del sistema IoT.

### Ataque 3: Man-in-the-Middle (MitM) mediante Evil Twin (Gemelo Malvado)

- **Metodología (*evil\_twin.sh* y *evil\_twin\_movil.conf*):** Este es el ataque más sofisticado. El objetivo fue crear un Punto de Acceso Wi-Fi falso que clonara perfectamente al Hotspot "Lab\_Movil", para obligar al ESP32 a conectarse al atacante en lugar del gateway legítimo.
  1. El Dongle TP-Link emitió un SSID clonado "Lab\_Movil" usando hostapd.
  2. La máquina Debian (LAPTOP\_DEBIAN) lanzó un servidor DHCP/DNS (dnsmasq) en la interfaz de ataque para asignar IPs falsas (10.0.0.x).
  3. Se configuró enrutamiento NAT (iptables MASQUERADE) para desviar el tráfico capturado en la interfaz de ataque (IFACE\_AP) hacia la interfaz con internet real (IFACE\_INTERNET/wlo1).
  4. Para forzar la reconexión, se lanzó simultáneamente un Ataque DoS breve (Ataque 2) sobre el canal legítimo 11. El ESP32, al perder la señal legítima, buscó automáticamente un AP con mejor señal y el mismo SSID, conectándose al Evil Twin emitido desde el Dongle TP-Link (más cercano).
- **Resultados:** El ESP32 se conectó exitosamente al Evil Twin atacante. Todo su tráfico MQTT pasó físicamente a través de la máquina Debian antes de ser reenviado a ThingsBoard. El auditor no solo pudo visualizar los datos (Capa 2 Sniffing), sino que se estableció la capacidad de **manipular** el payload MQTT antes de que llegara a la nube, comprometiendo totalmente la integridad de los datos reportados.

## Capítulo 3 - Medidas de Protección

Basado en los hallazgos críticos de la auditoría, se proponen las siguientes medidas de mitigación obligatorias para asegurar este sistema IoT.

### 3.1. Cifrado a Nivel de Aplicación (MQTTS)

La vulnerabilidad más grave es la falta de cifrado en el protocolo MQTT. El firmware del ESP32 debe actualizarse para utilizar **MQTTS** (MQTT sobre TLS), típicamente en el puerto **8883**, en lugar del puerto 1883.

- **Efecto:** MQTTS crea un túnel cifrado de extremo a extremo desde el ESP32 hasta el servidor de ThingsBoard. Incluso si un atacante logra descifrar el Wi-Fi o realizar un MitM, solo verá datos cifrados por TLS, imposibles de leer o manipular, preservando la confidencialidad e integridad de la telemetría IoT.

### 3.2. Autenticación Robusta del Servidor (Verificación de Certificado CA)

Para mitigar definitivamente los ataques MitM (Evil Twin), no basta con cifrar. El ESP32 debe estar configurado para autenticar la identidad del servidor al que se conecta.

- **Efecto:** El ESP32 debe poseer el certificado raíz (CA) de ThingsBoard en su memoria (flash o NVS). Durante el "Handshake" TLS, el ESP32 debe verificar que el certificado presentado por el broker MQTT (por ejemplo, el Evil Twin del atacante) sea válido y esté firmado por la CA correcta. Si el Evil Twin presenta un certificado falso (autofirmado), el ESP32 **abortará la conexión inmediatamente**, evitando que el atacante intercepte o altere los datos sensibles (como el Token de telemetría).

### 3.3. Mejora de la Disponibilidad Wi-Fi (PMF)

Para mitigar los ataques DoS por desautenticación, se requiere actualizar la seguridad del Punto de Acceso (móvil o router) y del ESP32 para soportar e implementar tramas de gestión protegidas (PMF - IEEE 802.11w). WPA3 incluye PMF por defecto, por lo que deshabilitar WPA3 para forzar WPA2 (como se hizo durante la auditoría para facilitar el descifrado) introduce este riesgo de disponibilidad. Se recomienda forzar el uso de WPA3 Personal si el ESP32-C6 y el AP lo soportan.

### 3.4. Verificación de BSSID (MAC Pinning)

A diferencia de un usuario humano que elige una red por su nombre (SSID), el ESP32 debe ser configurado para validar la identidad física del punto de acceso.

5. **Descripción:** En el firmware del ESP32, dentro de la estructura de configuración Wi-Fi (`wifi_config_t`), se debe activar el campo `ssid_set` y proporcionar la

dirección MAC exacta del Hotspot legítimo (en este caso, la del Samsung: 96:69:97:89:E2:90).

6. **Efecto contra MitM:** Durante el ataque de **Evil Twin** realizado con el script `evil_twin.sh`, el atacante utiliza un adaptador USB (TP-Link) que tiene una dirección MAC distinta a la del móvil. Si el ESP32 tiene activado el "MAC Pinning", rechazará cualquier intento de conexión que provenga de un dispositivo que no sea el Samsung original, aunque el nombre de la red (SSID) y la contraseña sean idénticos. Esto neutraliza la fase de asociación del ataque Man-in-the-Middle.

### 3.5. Implementación de Tramas de Gestión Protegidas (PMF)

Para mitigar los ataques de Denegación de Servicio (DoS) detectados en la auditoría:

- **Descripción:** Activar el estándar IEEE 802.11w en el ESP32 y en el Punto de Acceso.
- **Efecto:** Esto cifra las tramas de desautenticación. Cuando el script `ataque_iot.sh` intente enviar paquetes de desconexión falsos utilizando `aireplay-ng`, el ESP32 los ignorará al no estar firmados criptográficamente por el AP legítimo, manteniendo la disponibilidad del servicio.



## Conclusión

La implementación actual es **crítica**. El uso de MQTT sin TLS en una red inalámbrica Wi-Fi WPA2 es insuficiente. La implementación inmediata de MQTTS y la verificación de certificados son las únicas medidas que garantizan la integridad y confidencialidad del sistema auditado.

## Repositorio de Código y Artefactos

URL del Repositorio: [<https://github.com/ariegd/miot-sl/tree/labF/src/labF>]

El repositorio contiene la estructura de archivos necesaria para replicar el entorno de laboratorio, incluyendo los scripts de ataque y los archivos de configuración de red.

## Bibliografía

INCIBE-CERT. (2019). Ciberseguridad en las comunicaciones inalámbricas en entornos industriales.

INCIBE-CERT. (2023). Estudio de herramientas para la actividad de reconocimiento.

INCIBE-CERT. (2019). Guía de acceso seguro a los dispositivos de campo.

INCIBE-CERT. (2023). Defensa de endpoints en sistemas de control industrial.

INCIBE-CERT. (2019). Guía de análisis forense en Sistemas de Control Industrial.

INCIBE-CERT. (2017). Diseño y Configuración de IPS, IDS y SIEM en Sistemas de Control Industrial.

INCIBE-CERT. (2023). Estudio de análisis de firmware en dispositivos industriales.

INCIBE-CERT. (2019). Guía de implantación de un honeypot industrial.

Google. (2026). Gemini 3.1 Pro [Modelo de Lenguaje de Gran Tamaño]. Herramienta de Inteligencia Artificial utilizada como asistente técnico durante la elaboración de esta auditoría para el análisis de salidas de terminal (tshark), la estructuración y revisión de la redacción del informe técnico, y la generación de código de renderizado (Mermaid) para los diagramas de arquitectura de hardware.